



Oficina Avaliação de Riscos de Segurança e Privacidade

Secretaria de Governo Digital

novembro/2020

Lei Geral de Proteção de Dados – Lei 13.709/18

Licenciado a: dssenna@gmail.com

Estratégia de Governo Digital 2020-2022 / Um Governo Confiável

Objetivo 10: Implementação da Lei Geral de Proteção de Dados - LGPD no Governo

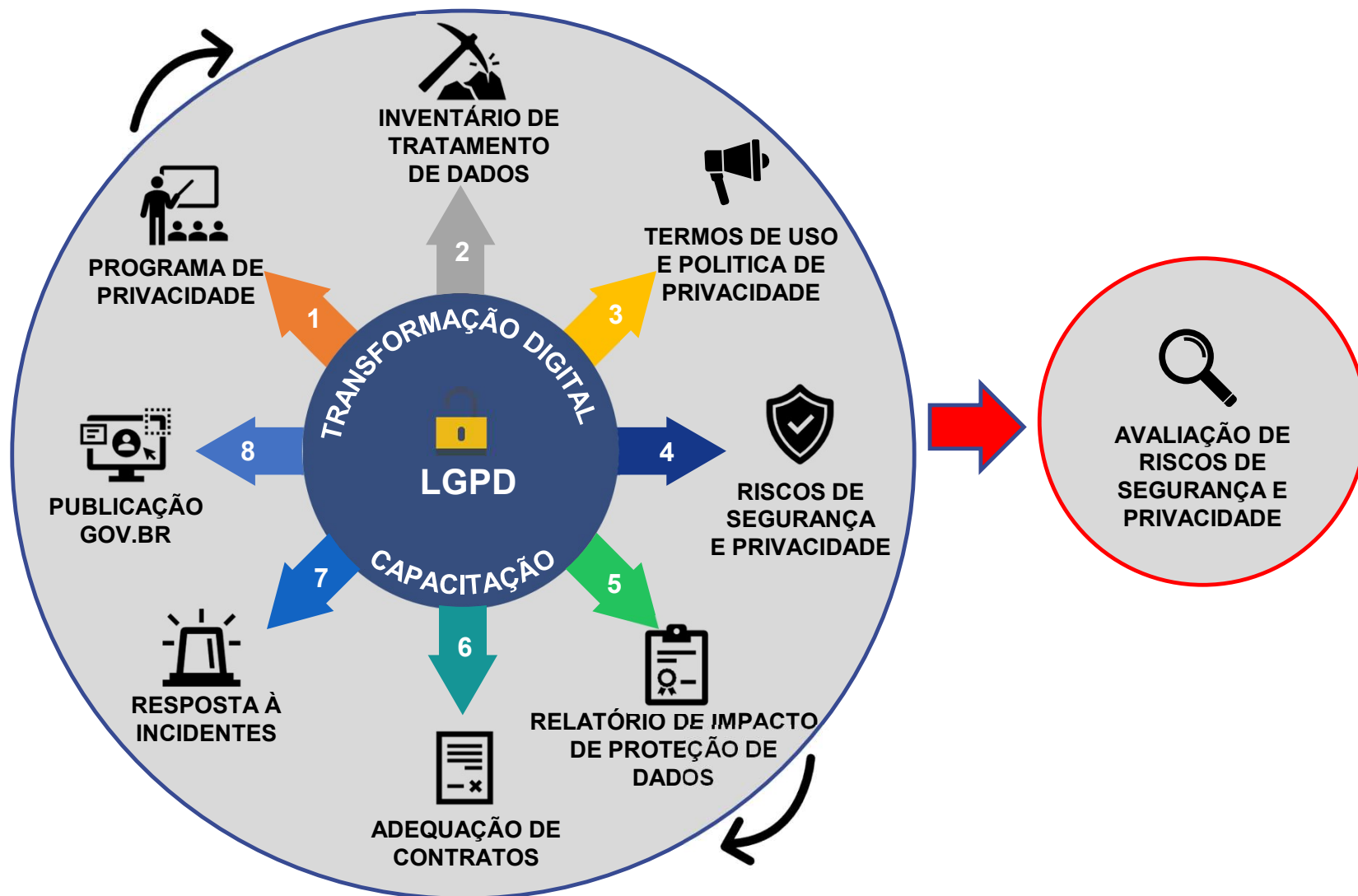
Iniciativa 10.1: Estabelecer método de adequação e conformidade dos órgãos com os requisitos da Lei Geral de Proteção de Dados, até 2020

PROJETO ADEQUAÇÃO À LGPD

Objetivo: Definir e implementar estratégia para atuar preventivamente nas frentes de segurança da informação e privacidade de dados, com o intuito de fomentar a cultura de proteção de dados, implementando ações que visam avançar no processo de adequação à LGPD, minimizando os riscos.



Oficinas



Objetivo da Oficina



Realizar avaliação de riscos de segurança e privacidade nos sistemas que tratam dados pessoais no âmbito institucional com base nas orientações do Guia de Avaliação de Riscos de Segurança e Privacidade elaborado pela Secretaria de Governo Digital do Ministério da Economia.

Agenda da Oficina

1

Avaliação de Riscos de Segurança e Privacidade

- Alinhamento de expectativas
- Contexto

2

Organização

- Etapas de construção
- Avaliação de riscos
- Documentos auxiliares

3

Ferramenta automatizada em forma de questionário

- Retorna o nível de risco do Sistema analisado diante dos 14 riscos elencados no Guia de Boas Práticas da LGPD (CCGD, 2020) para as perguntas respondidas.
- A saída serve como entrada para o Relatório de Impacto à Proteção de Dados pessoais (RIPD).

Licenciado a: dssenna@gmail.com

Material da Oficina

Anexo I

- Documento – Controles de Segurança e Privacidade – Anexo I
<[https:// xxxxxx](https://xxxxxx)>

Ferramenta

- Ferramenta automatizada da avaliação de riscos de segurança e privacidade

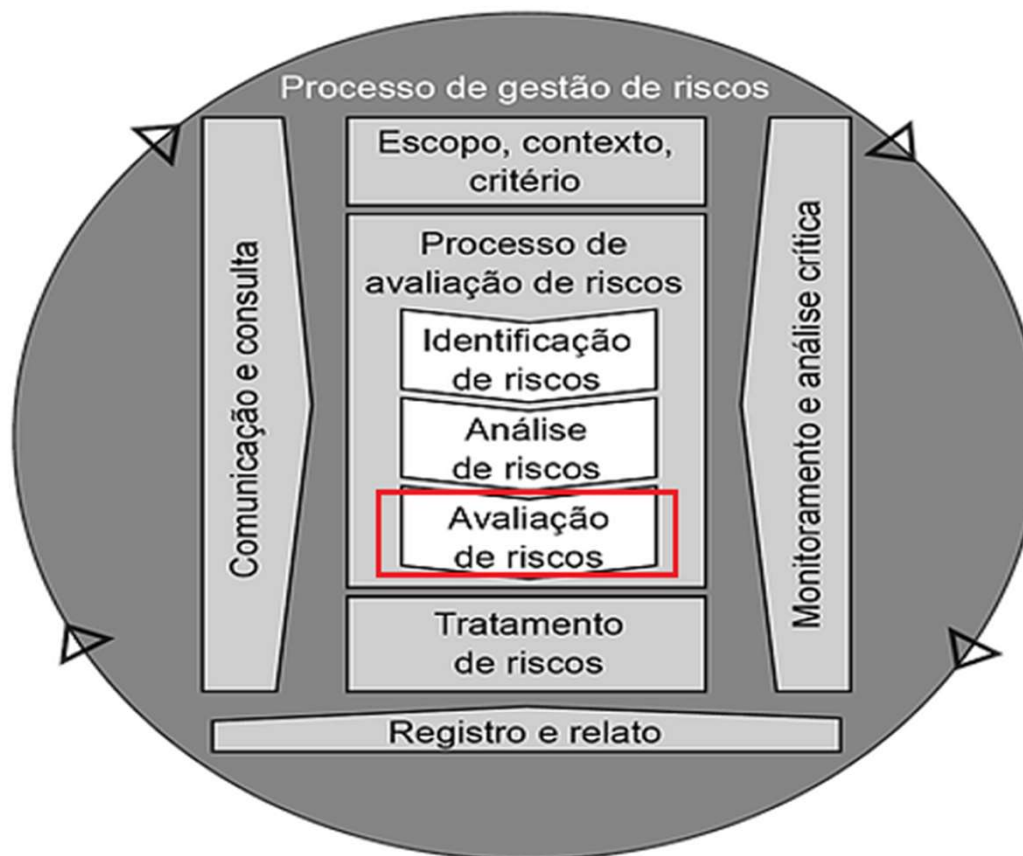
1

Avaliação de Riscos de Segurança e Privacidade

- Alinhamento de expectativas
- Contexto

Alinhamento de expectativas

Escopo



Processo de Gestão de Riscos – (ABNT NBR ISO/IEC 31000:2018)

Guia de Boas Práticas LGPD

1

OBJETIVO

Fornecer orientações básicas às instituições públicas no sentido de nortear as operações de tratamento de dados pessoais em observância aos requisitos previstos pela LGPD.

2

ELABORAÇÃO

Comitê Central de Governança de Dados - CCGD
Decreto nº 10.046, de 09/10/2019.

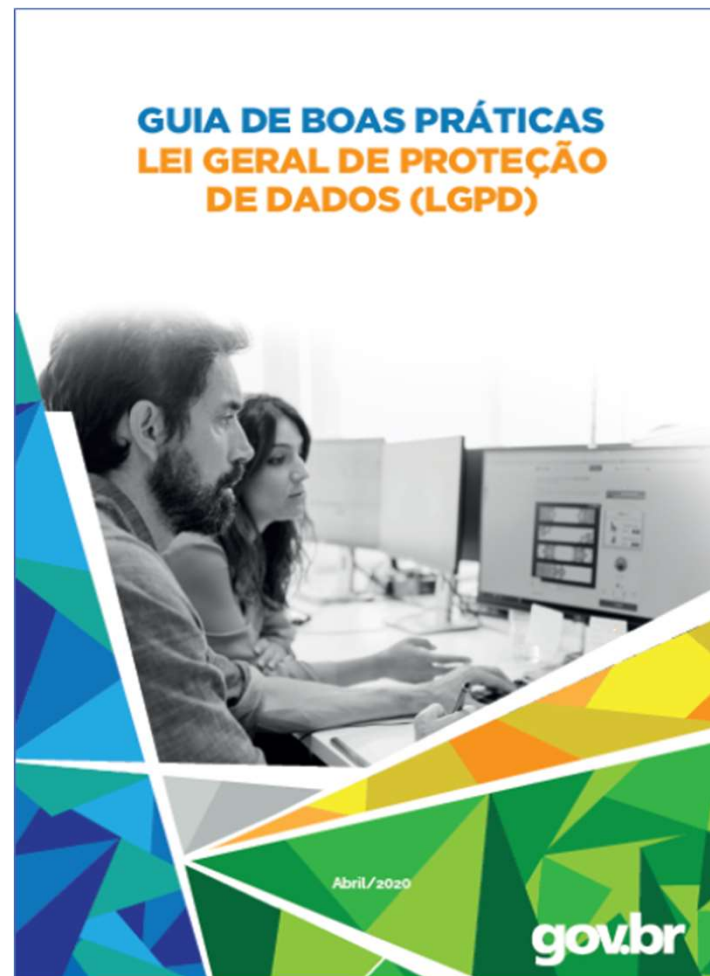
3

PUBLICAÇÃO

Abril de 2020
Revisões periódicas

4

DISPONÍVEL EM:



<https://www.gov.br/governodigital/pt-br/governanca-de-dados/guia-de-boas-praticas-lei-geral-de-protecao-de-dados-lgpd>

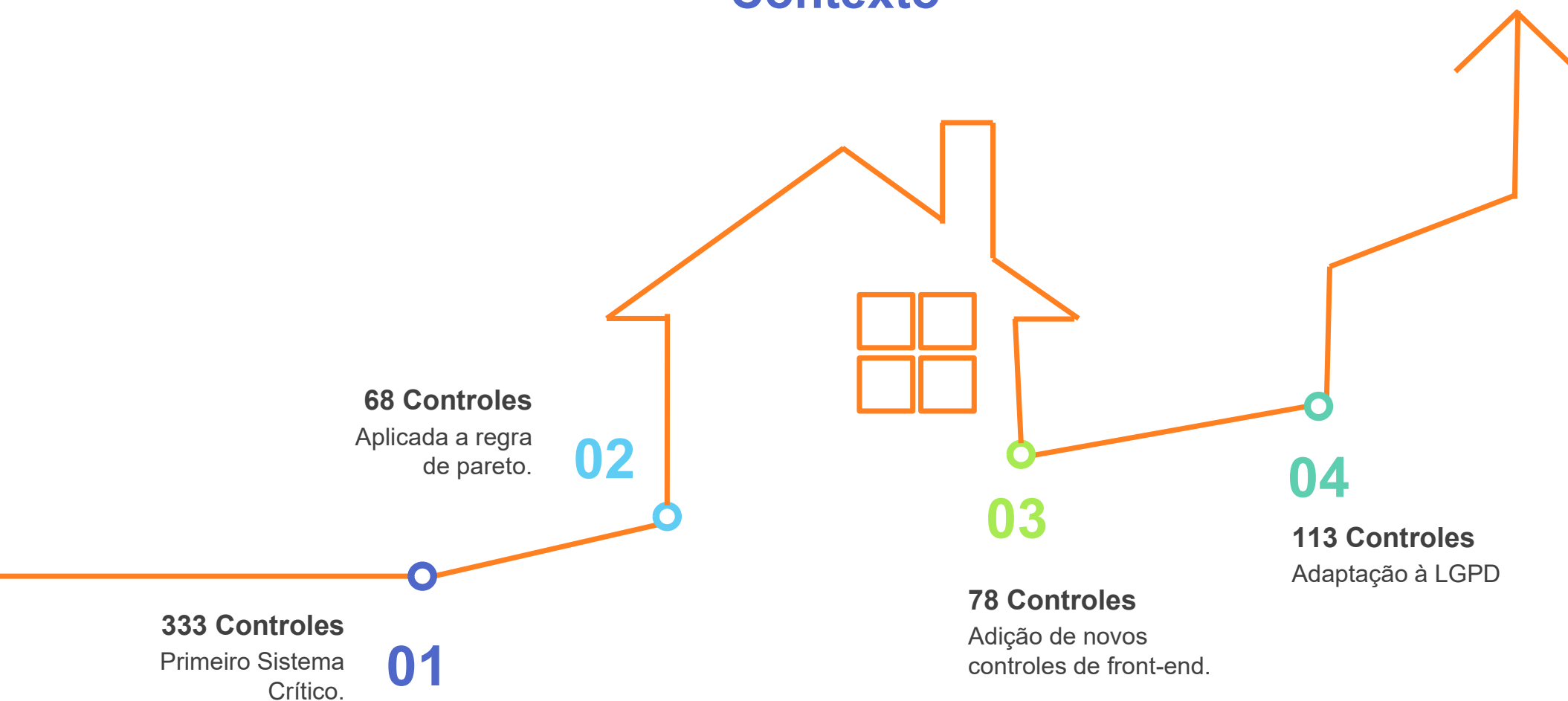
Licenciado a: dssenna@gmail.com

Alinhamento de expectativas

Benefícios



Contexto



2

Organização

- Etapas de elaboração
 - Referências
 - Dimensões
 - Medidas
 - Riscos
- Avaliação de Riscos

Etapas de elaboração

Principais referências internacionais



*International Organization for
Standardization*



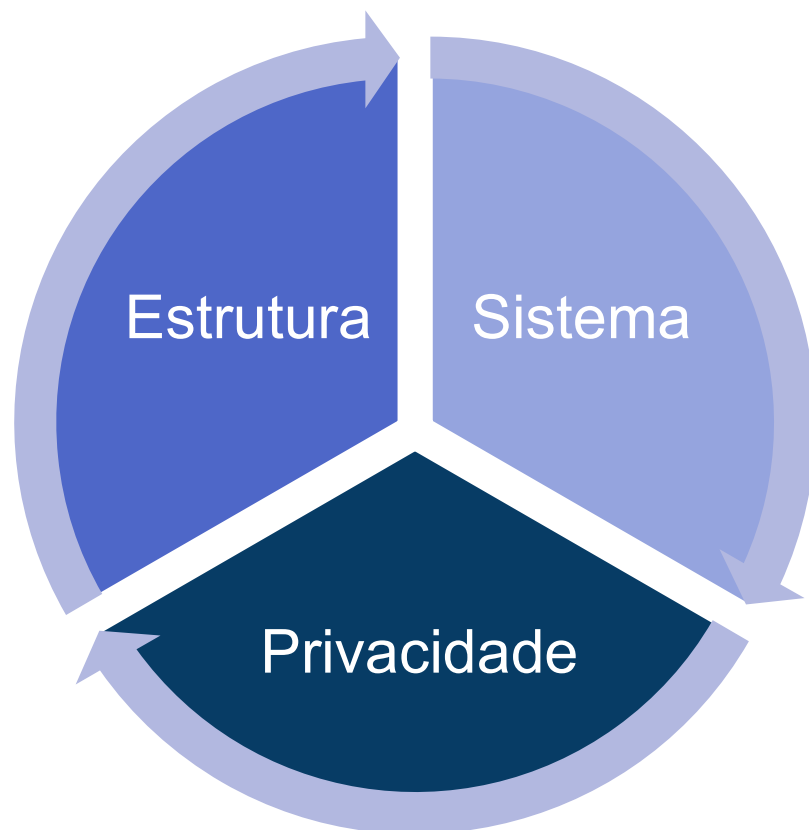
*Open Web
Application
Security Project*



*Control Objectives for
Information and Related
Technologies*

Etapas de elaboração

Dimensões



Etapas de elaboração

Dimensões

- Dimensão Estrutura (36 controles)
 - Aspectos estruturais (processos e infraestrutura)

Dimensão Estrutura	
ID	Controle
15	As mudanças são comunicadas para todas as partes interessadas?
16	Existe um prazo formalmente definido para o tratamento de vulnerabilidades técnicas relevantes identificadas?
18	Há um processo de análise e monitoramento de vulnerabilidades?

Etapas de elaboração

Dimensões

- Dimensão Sistema (39 controles)
 - Características de sistema (desenvolvimento seguro)

Dimensão Sistema	
ID	Controle
48	O sistema em análise segue uma política de senha com definição de tamanho mínimo e formato?
55	O sistema implementa restrições/limitadores para sucessivas tentativas de acesso mal sucedidas?
66	É realizada análise estática e/ou análise dinâmica dos requisitos de segurança cibernética do sistema?

Etapas de elaboração

Dimensões

- Dimensão Privacidade (38 controles)
 - Conformidade legal com a privacidade dos dados pessoais

Dimensão Privacidade	
ID	Controle
76	As permissões de acesso (incluir, consultar, alterar, excluir) dos usuários que executam a operação de processamento de dados pessoais se limitam ao mínimo necessário para realizar o processamento?
81	A instituição utiliza técnicas ou métodos apropriados para garantir exclusão ou destruição segura de dados pessoais (incluindo originais, cópias e registros arquivados), de modo a impedir sua recuperação?
105	No processamento de dados, é utilizado o mínimo necessário de dados pessoais para atingir a finalidade pretendida?

Etapas de elaboração Medidas de Segurança

Medidas de Segurança (12)	Descrição (Objetivo dos controles)
Continuidade de Negócio	Manter a operação da atividade, apesar das adversidades enfrentadas.
Controles Criptográficos	Oferecer um meio seguro para as comunicações e armazenamento de registros (dados, informações e conhecimento).
Controles de Acesso Lógico	Limitar os acessos indevidos ao sistema.
Controles de Segurança em Redes, Proteção Física e do Ambiente	Evitar acessos indevidos às estruturas internas.
Cópia de Segurança	Realizar e manter cópias com temporariedade de execução e testes (simulações) de que os procedimentos adequados foram implantados e estão funcionais.
Desenvolvimento Seguro	Atender critérios de segurança da informação, desde a concepção do produto.
Gestão de Capacidade e Redundância	Manter a disponibilidade do serviço.
Gestão de Mudanças	Acompanhar as mudanças, comunicar aos interessados e identificar potenciais riscos.
Gestão de Riscos	Identificar, avaliar, gerenciar e monitorar os riscos identificados.
Registro de Eventos, Rastreabilidade e Salvaguarda de Logs	Registrar eventos com atributos de rastreabilidade e proteger de alteração e acessos indevidos.
Resposta a Incidente	Realizar a coleta, a preservação de evidências, o tratamento e a resposta à incidentes de segurança.
Segurança Web	Elevar os níveis de segurança (da camada de front-end) nos serviços de acessos eletrônicos.

Adaptadas da ABNT NBR ISO/IEC 27002:2013

Licenciado a: dssenna@gmail.com

Etapas de elaboração Medidas de Privacidade

Medidas de Privacidade (11)	Descrição (Objetivo dos controles)
Abertura, Transparência e Notificação	Atender o princípio de transparência da LGPD (art. 6º, inciso VI).
<i>Compliance</i> com a Privacidade	Atender a legislação de proteção de dados, monitorar e auditar a privacidade.
Consentimento e Escolha	Obter consentimento do titular (art. 7º, I), desde que não se enquadre nas demais hipóteses previstas pelo art. 7º e 11 da LGPD.
Controles de Acesso e Privacidade	Limitar acessos indevidos às operações de tratamento de dados pessoais (LGPD, art. 6º, Incisos VII e VIII).
Legitimidade e Especificação de Propósito	Realizar tratamento para propósitos legítimos, específicos, explícitos e informados ao titular (LGPD, art. 6º, I).
Limitação da Coleta	Limitar a coleta ao mínimo necessário para a realização de suas finalidades (LGPD, art. 6º, III).
Minimização dos Dados	Minimizar os dados utilizados no processamento (LGPD, art. 6º, III).
Participação Individual e Acesso	Assegurar que os direitos do titular dos dados pessoais são atendidos, a exemplo do livre acesso aos seus dados (LGPD, art. 6º, IV).
Precisão e qualidade	Assegurar que os dados coletados são exatos e relevantes para o cumprimento da finalidade do tratamento (LGPD, art. 6º, V).
Responsabilização	Adotar medidas eficazes e capazes de comprovar a observância e o cumprimento das normas de proteção de dados pessoais (LGPD, art. 6º, X).
Uso, Retenção e Limitação de Divulgação	Assegurar aos titulares os direitos fundamentais de liberdade, de intimidade e de privacidade nos termos da LGPD ao realizar o tratamento de dados pessoais.

Adaptadas da ISO/IEC 29100:2011

Licenciado a: dssenna@gmail.com

Etapas de elaboração Riscos (CCGD, 2020)

ID	Riscos	Escopo do risco
1	Acesso não autorizado	Acesso indevido (permissões indevidas) a um ambiente físico ou lógico.
2	Coleção excessiva	Coleta de dados pessoais em quantidade superior ao mínimo necessário à finalidade do tratamento ou atividade que fará uso do dado pessoal.
3	Compartilhar ou distribuir dados pessoais com terceiros fora da administração pública federal sem o consentimento do titular dos dados pessoais	Instituição não atende sua finalidade legal e compartilha os dados sem consentimento do titular dos dados pessoais (LGPD, art. 27).
4	Falha em considerar os direitos do titular dos dados pessoais (Ex.: perda do direito de acesso)	Garantia de atendimento dos direitos do titular, conforme descrito nos artigos 17 a 23 da LGPD. Art. 17. O titular dos dados pessoais tem direito a obter do controlador mediante requisição: I - confirmação da existência de tratamento; II - acesso aos dados; III - correção de dados incompletos, inexatos ou desatualizados; IV - anonimização, bloqueio ou eliminação de dados desnecessários, excessivos ou tratados em desconformidade com o disposto nesta Lei; VI - eliminação dos dados pessoais tratados com o consentimento do titular, exceto nas hipóteses previstas no art. 16 desta Lei; VII - informação das entidades públicas e privadas com as quais o controlador realizou uso compartilhado de dados; VIII - informação sobre a possibilidade de não fornecer consentimento e sobre as consequências da negativa; IX - revogação do consentimento, nos termos do § 5º do art. 8º desta Lei...

Adaptados da ISO/IEC 29134:2017

Etapas de elaboração Riscos (CCGD, 2020)

ID	Riscos	Escopo do risco
5	Falha ou erro de processamento (Ex.: execução de script de banco de dados que atualiza dado pessoal com informação equivocada, ausência de validação dos dados de entrada etc.)	Dados de entrada que não são corretamente validados, operações de tratamento automatizadas de sistema que alteram de maneira indevida a composição do dado armazenado.
6	Informação insuficiente sobre a finalidade do tratamento	O tratamento de dados pessoais realizado de forma eletrônica ou documento em papel deve atender a uma finalidade e ser exposto de forma transparente e clara ao detentor dos dados pessoais.
7	Modificação não autorizada	Usuário sem permissões de alteração para um determinado dado pessoal ou registro realiza a modificação não autorizada. Um processamento indevido pode gerar uma modificação não autorizada.
8	Perda	Perdas provocadas por ações intencionais de usuários oriundas de uma exclusão indevida ou devida e não comunicada, e provenientes de ações não intencionais como falhas em sistemas, sobrescrita de dados, falhas em hardware, entre outras.
9	Reidentificação de dados pseudonimizados	Dados pessoais podem ser reidentificados por cruzamento simples de dados pessoais (LGPD, art. 12 e 13).

Adaptados da ISO/IEC 29100:2011

Licenciado a: dssenna@gmail.com

Etapas de elaboração Riscos (CCGD, 2020)

ID	Riscos	Escopo do risco
10	Remoção não autorizada	Usuário não tem a permissão para retirar ou copiar dados pessoais para outro local.
11	Retenção prolongada de dados pessoais sem necessidade	O término da prestação de um serviço ou do prazo da retenção dos dados pessoais para fins legais deve culminar com a exclusão e/ou descarte seguro(a) dos dados pessoais.
12	Roubo	Dados roubados nas dependências interna do controlador/operador, falhas nos controles de segurança dos sistemas (a exemplo da ausência ou fraca criptografia, falha de sistema que permita escalação de privilégio ou tratamentos indevidos), entre outras.
13	Tratamento sem consentimento do titular dos dados pessoais (caso o tratamento não esteja previsto em legislação ou regulação pertinente)	Controlador de dados pessoais não obtém consentimento do titular para realizar um tratamento de dados pessoais sem embasamento legal.
14	Vinculação ou associação indevida, direta ou indireta, dos dados pessoais ao titular	A realização de operação de processamento de dados pessoais deve estar em conformidade com a LGPD. Qualquer operação de processamento que não atenda esse requisito pode produzir informações com vinculações ou associações indevidas.

Adaptados da ISO/IEC 29100:2011

Licenciado a: dssenna@gmail.com

Avaliação de riscos (CCGD, 2020)

Parâmetros escalares

CLASSIFICAÇÃO	VALOR
Baixo	5
Moderado	10
Alto	15

Matriz de Probabilidade e Impacto

Probabilidade (P)	15	75	150	225
	10	50	100	150
	5	25	50	75
		5	10	15
		Impacto (I)		

Probabilidade: chance de algo acontecer

Impacto: resultado de um evento que afeta o objetivo

Nível de risco: magnitude de um risco ou combinação de riscos - obtido pela multiplicação dos parâmetros $P \times I$

Avaliação de riscos

Fluxo de Saídas (CCGD, 2020)

ID	RISCO REFERENTE AO TRATAMENTO DE DADOS PESSOAIS	P	I	NÍVEL DE RISCO (P X I)
R01	Acesso não autorizado.	10	15	150
R02	Modificação não autorizada.	10	15	150
R03	Perda	5	15	75
R04	Roubo	5	15	75
R05	Remoção não autorizada.	5	15	75
R06	Coleção excessiva.	10	10	100
....		...	...	...
...	...	...	...	...
R11	Retenção prolongada de dados pessoais sem necessidade.	10	5	50
R12	Vinculação ou associação indevida, direta ou indireta, dos dados pessoais ao titular.	5	15	75
R13	Falha ou erro de processamento (Ex.: execução de script de banco de dados que atualiza dado pessoal com informação equivocada, ausência de validação dos dados de entrada etc.).	5	15	75
R14	Reidentificação de dados pseudonimizados.	5	15	75

RISCO	MEDIDA(S)	EFEITO SOBRE RISCO	RISCO RESIDUAL			MEDIDA(S) APROVADA(S)
			P	I	(P X I)	
R01 Acesso não autorizado.	1. Controle de acesso Lógico.	Reduzir	5	10	50	Sim
	2. Desenvolvimento seguro.					
	3. Segurança em Redes.					

Exemplos de medidas aplicadas para reduzir o risco

Riscos e nível de risco (diagnóstico inicial)

Legenda: P – Probabilidade; I – Impacto.

Licenciado a: dssenna@gmail.com

Avaliação de riscos

Definição da avaliação

Peso	Descrição
0	Controle não se aplica ao risco
0,5	Controle se aplica
1	Controle se aplica e prioritário

Pesos

23

Há um **sistema para monitoramento de aplicações**, alertas e vulnerabilidades utilizado para auxiliar na detecção e tratamento de incidentes de segurança cibernética (IPS, IDS, etc.)?

Matriz de Pesos e Tipos de Controle por Riscos

ID	1	2	3	4	5	6	7	8	9	10	11	12
1	1			0,5	0,5		1	1	1	1	0,5	0,5
2	1				0,5							1
3	1				0,5							0,5
4	1			1	0,5	0,5	0,5	0,5				0,5
5	1	0,5	0,5		0,5	0,5						1
6	1				0,5							0,5
7	1			1	0,5		0,5	0,5	1	1	1	0,5
8	1	1	1	1	0,5		0,5	0,5	1	0,5	1	0,5
9	1				1							0,5
10	1			1	0,5		1	1	1	1	0,5	1
11	1				1							0,5
12	1			1	0,5		1	1	1	1	0,5	1
13	1				0,5	1						0,5
14	1				0,5	1						0,5

Legenda

Controle	Prevenção
Risco	Mitigação
Controle não ativo para o Risco	Prevenção e Mitigação

Avaliação de riscos

Definição da avaliação

Diretrizes:

- O sistema a ser avaliado inicia com nível de risco Alto (probabilidade Alta e impacto Alto);
- São utilizados 113 controles na avaliação;
- Controles do tipo prevenção atuam na redução da probabilidade e controles do tipo mitigação na redução do impacto.

Risco	Total de Controles	Total de Controles de Prevenção	Total de Controles de Mitigação	Total de Controles de Prevenção e Mitigação	Total de Controles que atuam na Probabilidade	Total de Controles que atuam no Impacto
Acesso não autorizado	20	8	7	5	(8+5) 13	(7+5) 12

Avaliação de riscos

Método

Cálculo da probabilidade e impacto

- Valor entre 0 e 1;
- 1 indica que todos os controles foram implementados;
- 0 indica que nenhum dos controles foram implementados.

Cálculo da Probabilidade

- **Probabilidade** = Total de Pesos dos **Controles de Prevenção Aplicados** ao Risco / (Total de Pesos dos **Controles de Prevenção Associados** ao Risco – Total de Pesos dos **Controles de Prevenção Que Não se Aplica** ao Risco)

Cálculo do Impacto

- **Impacto** = Total de Pesos dos **Controles de Mitigação Aplicados** ao Risco / (Total de Pesos dos **Controles de Mitigação Associados** ao Risco – Total de Pesos dos **Controles de Mitigação Que Não se Aplica** ao Risco)

Avaliação de riscos

Método

Controles implementados

- Resultado obtido pelos cálculos de probabilidade e impacto (valor entre 0 e 1) transformado em porcentagem;
- Evolução gradual da classificações Alta, Moderada e Baixa;

Controles implementados	Probabilidade	Impacto
0 a 50 por cento	Alta	
50 a 85 por cento	Moderada	Alto
85 a 100 por cento	Baixa	Moderado

Adaptados do Cobit 2019

Licenciado a: dssenna@gmail.com

Avaliação de riscos

Exemplo

Representação dos controles vinculados aos riscos, pesos e tipos

Risco	Controle 1	Controle 2	Controle 3	Controle 4	Controle 5	Controle 6	Controle 7	Controle 8	Controle 9	Controle 10
Acesso não autorizado	1			0,5	0,5		1	0,5		0,5
Coleção excessiva	1	1			1			1	1	

Tipo do controle
Mitigação
Prevenção
Mitigação e Prevenção
Controle não ativo

Respostas para o sistema XPTO

Análise	Controle 1	Controle 2	Controle 3	Controle 4	Controle 5	Controle 6	Controle 7	Controle 8	Controle 9	Controle 10
Resposta	Aplicado	Não Aplicado	Não se Aplica	Aplicado	Não Aplicado	Não se Aplica	Aplicado	Não Aplicado	Não se Aplica	Aplicado
Legenda										
Aplicado	Controle implementado									
Não Aplicado	Controle não implementado									
Não se Aplica	Controle não necessário para o sistema									

Avaliação de riscos

Exemplo

Representação dos controles vinculados aos riscos e tipos

Risco	Controle 1	Controle 2	Controle 3	Controle 4	Controle 5	Controle 6	Controle 7	Controle 8	Controle 9	Controle 10
Acesso não autorizado	Aplicado (1)	Não Aplicado	Não se Aplica	Aplicado (0,5)	Não Aplicado (0,5)	Não se Aplica	Aplicado (1)	Não Aplicado (0,5)	Não se Aplica	Aplicado (0,5)
Coleção excessiva	Aplicado (1)	Não Aplicado (1)	Não se Aplica	Aplicado	Não Aplicado (1)	Não se Aplica	Aplicado	Não Aplicado (1)	Não se Aplica (1)	Aplicado

Tipo do controle
Mitigação
Prevenção
Mitigação e Prevenção
Controle não ativo

Contabilização dos pesos para o sistema XPTO

Risco	Total de pesos de Controles de Prevenção Associados ao Risco	Total de pesos de Controles de Mitigação Associados ao Risco	Total de pesos de Controles de Prevenção Aplicados ao Risco	Total de pesos de Controles de Mitigação Aplicados ao Risco	Total de pesos de Controles de Prevenção Não se Aplica ao Risco	Total de pesos de Controles de Mitigação Não se Aplica ao Risco
Acesso não autorizado	3,5	2	2,5	1,5	0	0
Coleção excessiva	4	3	1	1	1	0

Exemplo: Controle 7 (1) + Controle 8 (0,5) + Controle 10 (0,5) + Controle 1 (1) + Controle 5 (0,5) = 3,5

Avaliação de riscos

Exemplo

- **Probabilidade** = Total de Pesos dos **Controles de Prevenção Aplicados** ao Risco / (Total de Pesos dos **Controles de Prevenção Associados** ao Risco – Total de Pesos dos **Controles de Prevenção Que Não se Aplica** ao Risco)
- **Impacto** = Total de Pesos dos **Controles de Mitigação Aplicados** ao Risco / (Total de Pesos dos **Controles de Mitigação Associados** ao Risco – Total de Pesos dos **Controles de Mitigação Que Não se Aplica** ao Risco)

Contabilização dos pesos para o sistema XPTO

Acesso não autorizado

$$\text{Probabilidade} = 2,5 / (3,5 - 0) = 2,5 / 3,5 = 0,71$$

$$\text{Impacto} = 1,5 / (2 - 0) = 1,5 / 2 = 0,75$$

Coleção excessiva

$$\text{Probabilidade} = 1 / (4 - 1) = 1 / 3 = 0,33$$

$$\text{Impacto} = 1 / (3 - 0) = 1 / 3 = 0,33$$

Risco	Total de pesos de Controles de Prevenção Associados ao Risco	Total de pesos de Controles de Mitigação Associados ao Risco	Total de pesos de Controles de Prevenção Aplicados ao Risco	Total de pesos de Controles de Mitigação Aplicados ao Risco	Total de pesos de Controles de Prevenção Que Não se Aplica ao Risco	Total de pesos de Controles de Mitigação Que Não se Aplica ao Risco
Acesso não autorizado	3,5	2	2,5	1,5	0	0
Coleção excessiva	4	3	1	1	1	0

Avaliação de riscos

Exemplo

Acesso não autorizado

$$\text{Probabilidade} = 2,5 / (3,5 - 0) = 2,5 / 3,5 = 0,71$$

$$\text{Impacto} = 1,5 / (2 - 0) = 1,5 / 2 = 0,75$$

Coleção excessiva

$$\text{Probabilidade} = 1 / (4 - 1) = 1 / 3 = 0,33$$

$$\text{Impacto} = 1 / (3 - 0) = 1 / 3 = 0,33$$

Classificação dos controles implementados

Controles implementados	Probabilidade	Impacto
0 a 50 por cento	Alta (15)	
50 a 85 por cento	Moderada (10)	Alto (15)
85 a 100 por cento	Baixa (5)	Moderado (10)

Matriz de Probabilidade e Impacto

		5	10	15
15	75	150	225	
10	50	100	150	
5	25	50	75	
		5	10	15
		Impacto (I)		

Nível de risco do sistema XPTO

Risco	Probabilidade (%)	Impacto (%)	Nível de risco
Acesso não autorizado	Moderada (71%)	Alto (75%)	Alto (150)
Coleção excessiva	Alta (33%)	Alto (33%)	Alto (225)

Documentos auxiliares

Anexo I - Controles

Avaliação de Riscos de Segurança e Privacidade

CHECKLIST – <Setor Responsável pelo levantamento>

Orientações: Anexar evidências dos itens respondidos como **SIM (controle aplicado)**. Definir prazos e encaminhamentos para a implementação dos itens respondidos como **NÃO (controle não aplicado)**. Justificar os itens respondidos como **N/A** (não aplicável).

Plataforma: <Plataforma>

Responsável pelo preenchimento: _____

ID	Dimensão Estrutura	Medida de Segurança e Privacidade	Resposta			Evidências / Prazos / Encaminhamentos	Referências
			Sim	Não	N/A		
1	Há uma matriz de responsabilidades com atribuição das responsabilidades pela segurança da informação na organização, pela proteção de dados (encarregado), identificação dos gestores de serviços com dados pessoais, operadores de tratamento de dados, de forma a evidenciar a segregação de funções e assegurar que colaboradores e partes externas entendam suas responsabilidades?	Responsabilização					Referências: NC nº 03/IN01/DSIC/GSIP R (item 5.3.7) e ABNT NBR ISO/IEC 27002:2013 (item 6.1.1)
2	Há mecanismos para monitoramento do uso dos recursos, de forma a atender as necessidades de capacidade futura e garantir o desempenho requerido das aplicações?	Gestão de Capacidade e Redundância					Referências: NC nº 10/IN01/DSIC/GSIP R (item 5.3.2) e ABNT NBR ISO/IEC 27002:2013 (12.1.3)
3	São implementados mecanismos e procedimentos para mitigar ataques de negação de serviço , tais como balanceamento de carga, proxy, firewall, etc.?	Continuidade de Negócio					Referências: NC nº 08/IN01/DSIC/GSIP R (Item 7.2) e ABNT NBR ISO/IEC 27002:2013 (13.1.2)

Documentos auxiliares

Anexo II.A

Anexo II.A – Dimensão Estrutura - Matriz de Pesos e tipos de controles por risco

Legenda	
Controle	Prevenção
Risco ²³	Mitigação
Controle não ativo para o Risco	Prevenção e Mitigação

ID	1	2	3	4	5	6	7	8	9	10	11	12	13	14	15	16	17	18	19	20	21	22	23	24	25	26	27	28	29	30	31	32	33	34	35	36	
1	1			0.5	0.5		1	1	1	1	0.5	0.5	0.5	1	0.5	1	1	1	1	1	1	1	1	1	1	0.5	0.5	0.5	0.5		1	1	1	1	1	1	
2	1				0.5							1	1	1	1		0.5																				
3	1				0.5							0.5	1	1	1																					1	
4	1			1	0.5	0.5	0.5	0.5				0.5	0.5	0.5	0.5		0.5										0.5	0.5	0.5	0.5	0.5		0.5				
5	1	0.5	0.5		0.5	0.5						1	1	1	1												0.5	1	1		0.5						
6	1				0.5							0.5	0.5	1	0.5		0.5																				
7	1			1	0.5		0.5	0.5	1	1	1	0.5	1	1	0.5	1	1	1	1	1	1	1	1	1	1	0.5	1	0.5	1	0.5		1	1	1	1	0.5	
8	1	1	1	1	0.5		0.5	0.5	1	0.5	1	0.5	1	1	0.5	1	1	1	1	1	1	1	1	1	1	0.5	1	0.5	1	0.5	1	1	1	1	1	0.5	
9	1				1							0.5	0.5	1	1																						
10	1			1	0.5		1	1	1	1	0.5	1	1	1	1	1	1	1	1	1	1	1	1	1	1	0.5	1	0.5	1	0.5		1	1	1	1	1	
11	1				1							0.5	0.5	0.5	0.5		1										1	0.5			1						
12	1			1	0.5		1	1	1	1	0.5	1	1	1	1	1	1	1	1	1	1	1	1	1	1	0.5	1	0.5	1	0.5	1	1	1	1	1	1	
13	1				0.5	1						0.5	0.5	1	1																					1	
14	1				0.5	1						0.5	0.5	1	1																						

²³ Ver Tabela 3 para identificar o risco tratado em cada linha.

O modelo de avaliação de riscos de segurança e privacidade



3

Ferramenta automatizada

Ferramenta automatizada

Orientações e preenchimento

Abertura do questionário

- <https://pesquisa.sisp.gov.br/index.php/468289?token=79ilxGYdTy69Wo1&lang=pt-BR>

Inicial (diagnóstico)

- <https://pesquisa.sisp.gov.br/index.php/468289?token=5Qwlsv4vnwtfqDN&lang=pt-BR>

Tratamento

- <https://pesquisa.sisp.gov.br/index.php/468289?token=QDzyASA6VUTjjK0&lang=pt-BR>

Preenchimento

- Instituição, nome do responsável, nome do sistema, fase da avaliação;
- Verificação dos 113 controles.
- <https://pesquisa.sisp.gov.br/index.php/468289?lang=pt-BR>

Guia de Avaliação de Riscos de Segurança e Privacidade

1

OBJETIVO

Apresentar orientações com o intuito de auxiliar os órgãos e entidades da Administração Pública Federal, direta, autárquica e fundacional a realizar a avaliação de riscos de segurança e privacidade em sistemas que tratam dados pessoais.

Guia de Avaliação de Riscos de
Segurança e Privacidade

2

ELABORAÇÃO

Coordenação-Geral de Segurança da Informação da Secretaria de Governo Digital – CGSIN/SGD.

LEI GERAL DE PROTEÇÃO DE
DADOS PESSOAIS (LGPD)

3

PUBLICAÇÃO

Novembro de 2020

Revisões periódicas

4

DISPONÍVEL EM:



Versão 1.0
Brasília, Novembro de 2020

<https://www.gov.br/governodigital/pt-br/governanca-de-dados/guia-de-avaliacao-de-riscos-de-seguranca-e-privacidade.pdf>

Licenciado a: dssenna@gmail.com

Contato
cgsin@economia.gov.br

MINISTÉRIO DA
ECONOMIA



**PÁTRIA AMADA
BRASIL**
GOVERNO FEDERAL

Secretaria de
Governo Digital